Laboratorio Propuesto: "Buscando Dispositivos Vulnerables con Shodan / Buscando Dispositivos en mi Red Pública"

Eric Oswaldo Aguilar Nova

Seguridad en Redes e Infraestructura Tecnológica – D01 – L / M 7-9

Mtro. Jose de Jesus Soto Sanchez

Práctica con Shodan

Para esta práctica se utilizó el sitio web de Shodan para la búsqueda de dispositivos y servicios que están expuestos a internet, donde el propósito fue encontrar algunos dispositivos con las direcciones IP que están justamente en shodan.

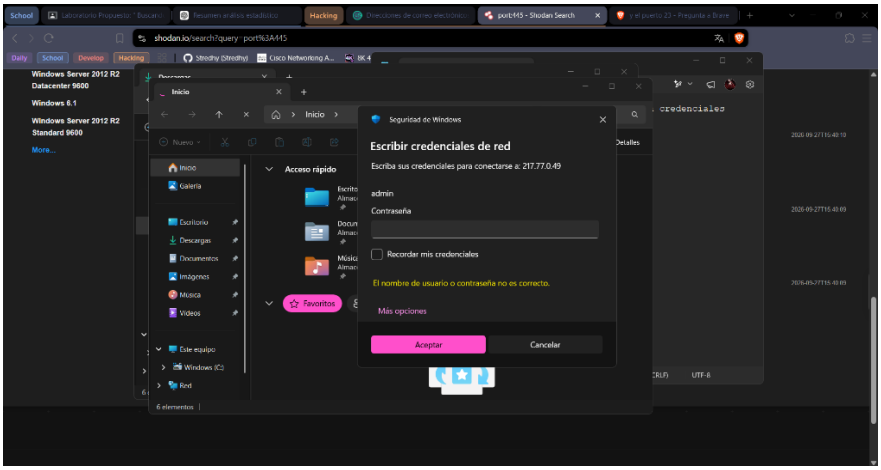
Practica

Durante la práctica primeramente era ingresar a la pagina Shodan y se utilizaron direcciones IP con los filtros product para identificar sistemas específicos.

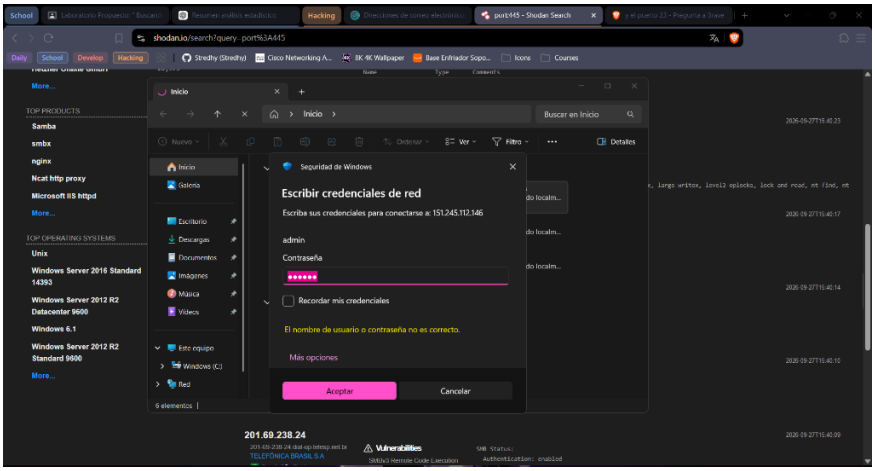
A continuación, se muestran los resultados de las búsquedas:

Carpetas remotas

151.245.112.146 - No se obtuvo acceso con credenciales predeterminadas



217.77.0.49 - No se obtuvo acceso con credenciales predeterminadas

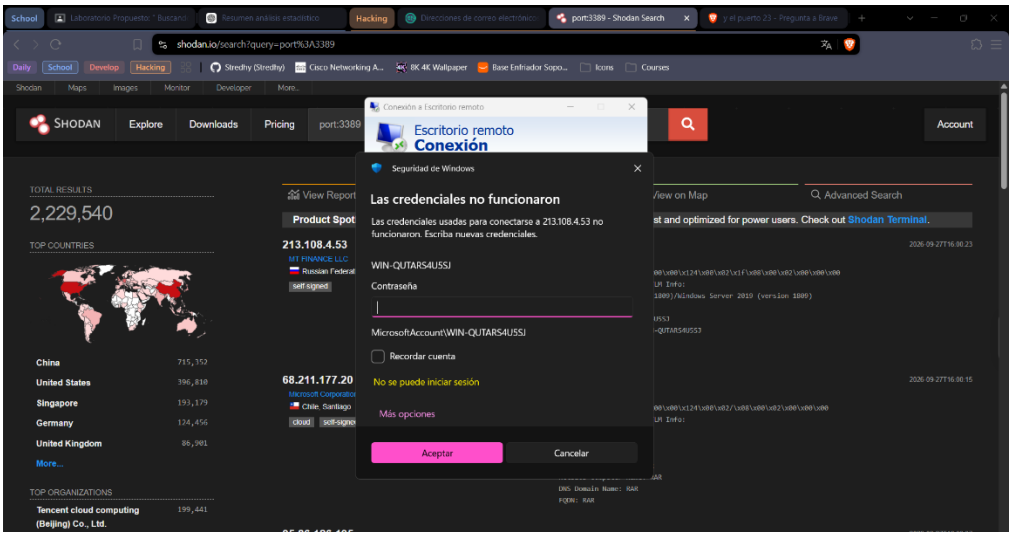


Se intento acceder a mas de 5 carpetas del explorador de archivos, sin embargo, no hubo suerte para acceder a las carpetas, se intentó utilizando credenciales defaults, pero las

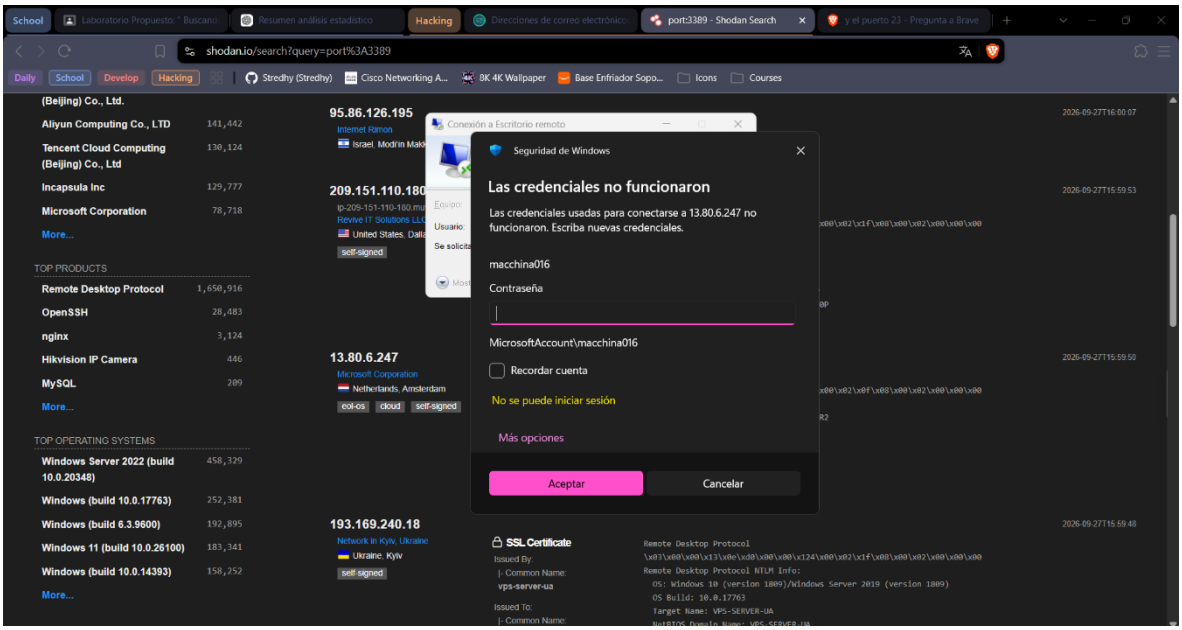
credenciales eran mas robustas de los esperado. A pesar de la cantidad de intentos, en este reporte solo se incluyeron 2 por que los resultados fueron exactamente los mismos para cada uno de los intentos.

Escritorios remotos

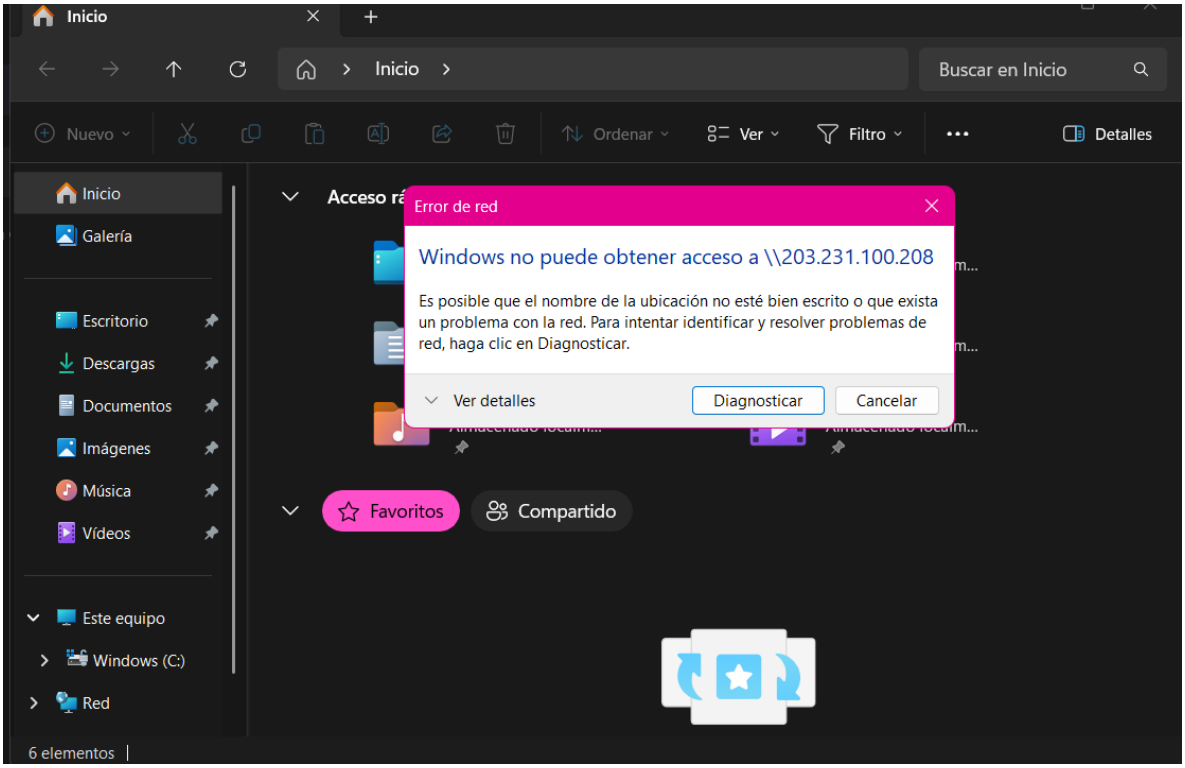
213.108.4.53 - No se obtuvo acceso con credenciales predeterminadas



13.80.6.247 - No se obtuvo acceso con credenciales predeterminadas



203.231.100.208 - No se obtuvo acceso con credenciales predeterminadas

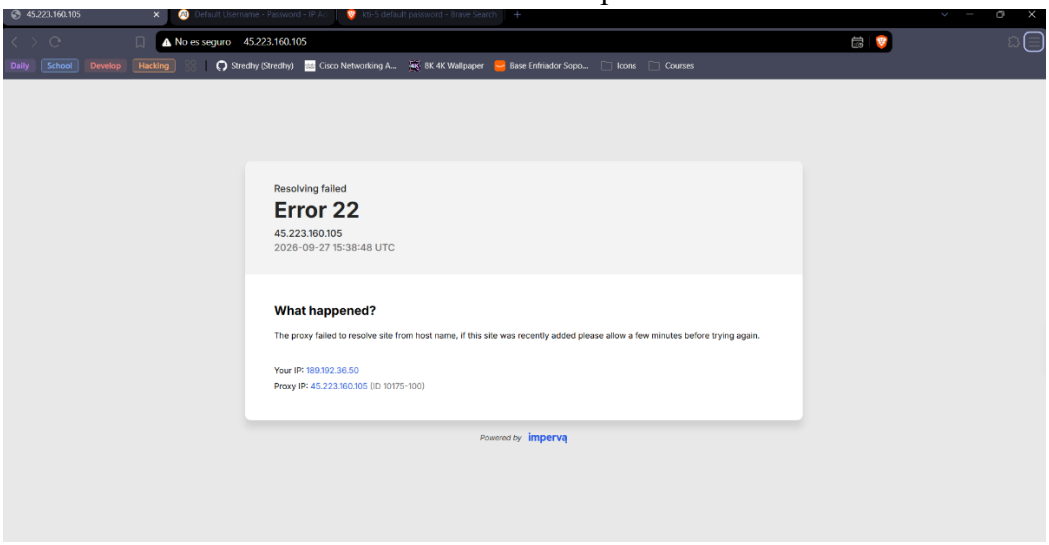


El escritorio remoto permite conectarse a un equipo desde otra ubicación. El problema de seguridad aparece cuando este tipo de servicio está expuesto directamente a Internet, ya que puede recibir intentos de conexión de personas externas.

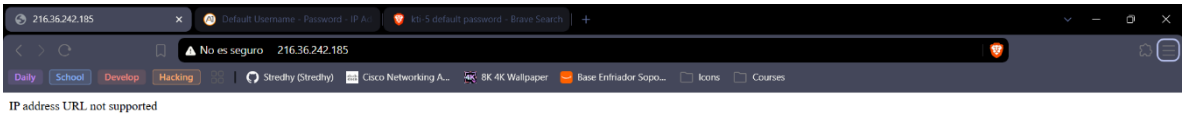
En los tres casos analizados no fue posible ingresar utilizando las credenciales predeterminadas.

Cámaras de seguridad y routers

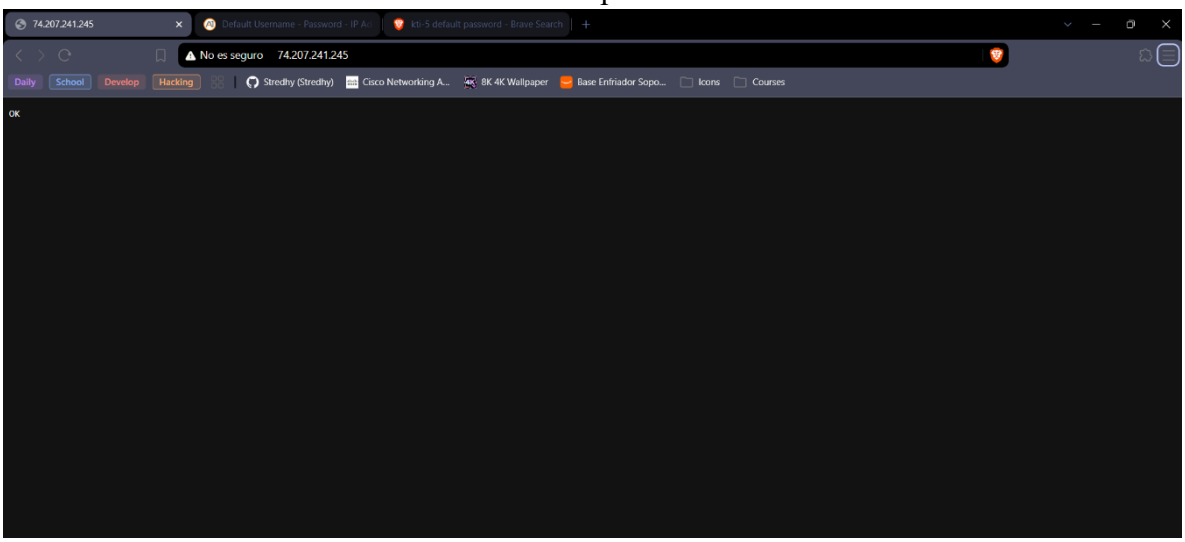
45.223.160.105 - Sin acceso con credenciales predeterminadas



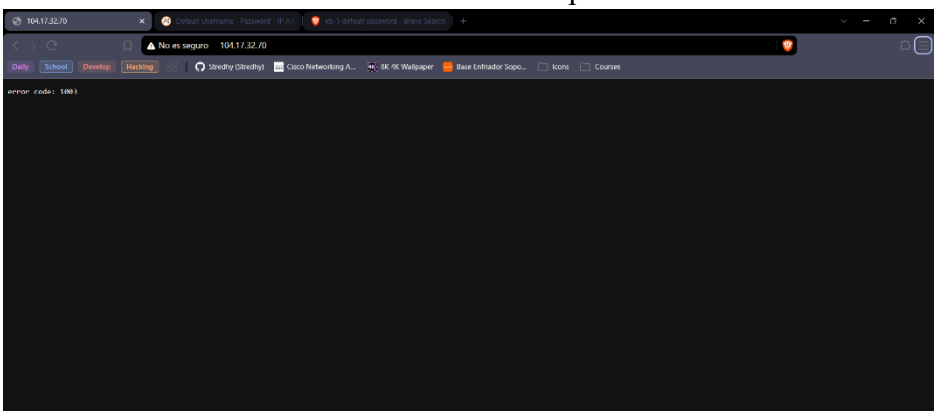
216.36.242.185 - Sin acceso con credenciales predeterminadas



74.207.241.245 - Sin acceso con credenciales predeterminadas



104.17.32.70 - Sin acceso con credenciales predeterminadas



Las cámaras de seguridad son dispositivos que pueden contener información sensible, principalmente cuando transmiten imágenes o video. Si una cámara se encuentra expuesta a Internet y tiene una configuración de seguridad deficiente, existe el riesgo de que una persona no autorizada pueda intentar acceder a ella.

En el caso de los routers, tener servicios de administración expuestos también puede representar un riesgo, ya que pueden revelar información sobre el dispositivo o permitir intentos de acceso.

Conclusión

Con esta práctica pude conocer de una forma más práctica el funcionamiento de Shodan y observar la cantidad de dispositivos y servicios que pueden encontrarse expuestos en Internet.

Se analizaron nueve direcciones IP, entre las cuales había servicios de escritorio remoto, carpetas remotas, cámaras de seguridad y routers. En los cinco casos donde se comprobaron credenciales predeterminadas, no se obtuvo acceso. También pude observar que el hecho de que un dispositivo aparezca en Shodan no significa automáticamente que sea vulnerable o que se pueda acceder a él. Sin embargo, tener un servicio expuesto a Internet aumenta la posibilidad de que personas externas intenten identificarlo o atacarlo.

En general, la práctica permitió comprender mejor el concepto de superficie de ataque y la importancia de revisar qué servicios de nuestros dispositivos están expuestos públicamente.

Practica con Advanced Port Scanner

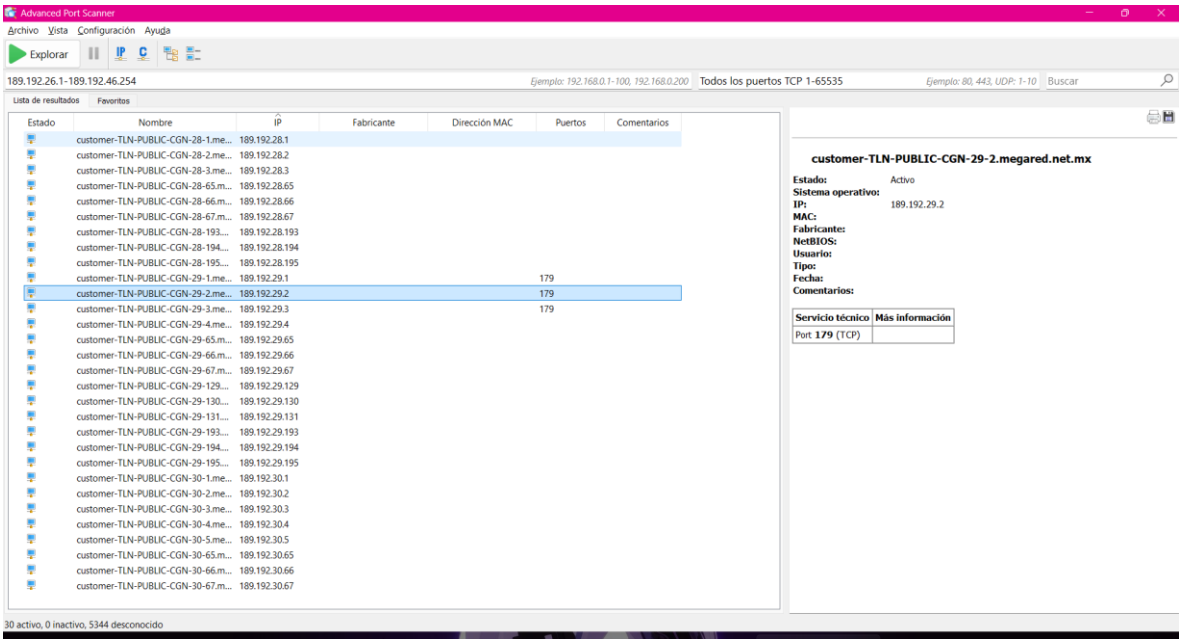
Rango de escaneo: *189.192.26.1 – 189.192.36.254*

Dispositivos encontrados: *3*

Puertos abiertos: *179/TCP (BGP) en los tres*

Intento de acceso: *no aplicable - BGP no tiene interfaz web, no es posible introducir credenciales*

El rango corresponde a infraestructura de enrutamiento inter-AS; los dispositivos no exponen servicios de gestión web, por lo que no es posible ingresar credenciales, no es aplicable a este tipo de infraestructura.



Conclusión

El escaneo de puertos realizado en un rango de 20 segmentos de red (basado en mi ip publica obtenida en https://www.whatismyip.com/es/), me permitió identificar 3 dispositivos con el puerto 179/TCP abiertos. Dichos resultados son consistentes con el rango escaneado. Lo cual corresponde a infraestructura de enrutamiento, y no a hosts de usuarios o dispositivos de consumo.

Esto demuestra que el espacio de direcciones IP públicas en un rango contiguo está ocupado predominantemente por infraestructura de red de operadores, y que los dispositivos con interfaces web administrables (routers domésticos, cámaras IP, NAS, etc.) se encuentran **detrás de NAT** y no poseen IP pública directa, por lo que no son alcanzables mediante escaneo del espacio público.